SecureCorp Security Assessment Engagement

Week 1 Deliverables — Build & Understand

Consultant: B.S.S.Praveen

Date: 27 September 2026

Engagement: Junior Cybersecurity Consultant Capstone (SecureCorp v2)

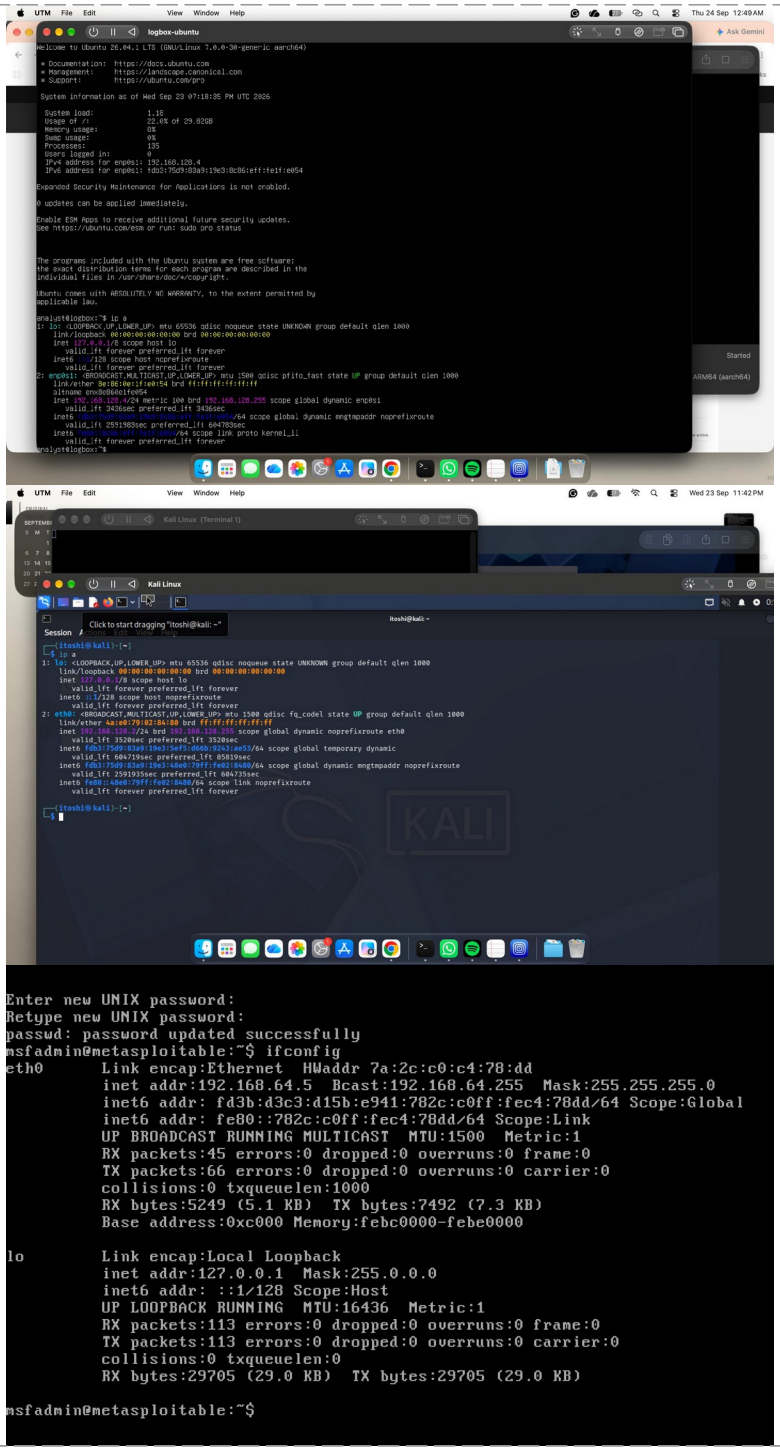
Task 1.1 — Isolated Lab Build

Environment: UTM (QEMU) on Apple Silicon macOS. Three virtual machines on a single Host Only network, isolated from the internet and any host network.

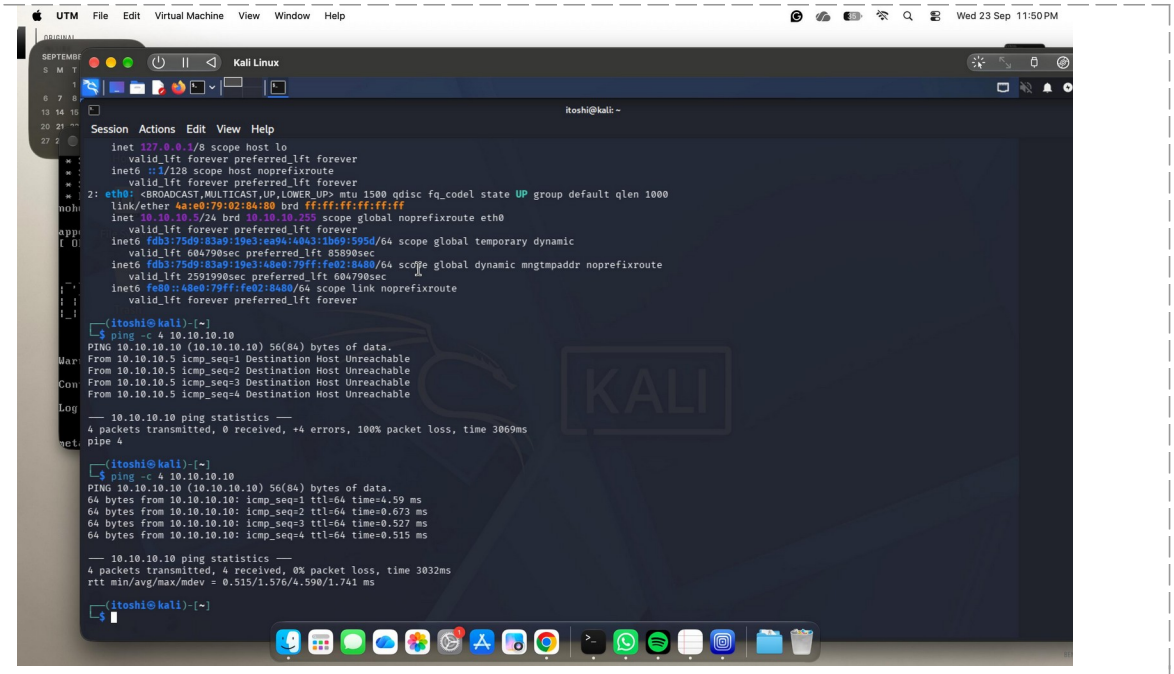
Network summary

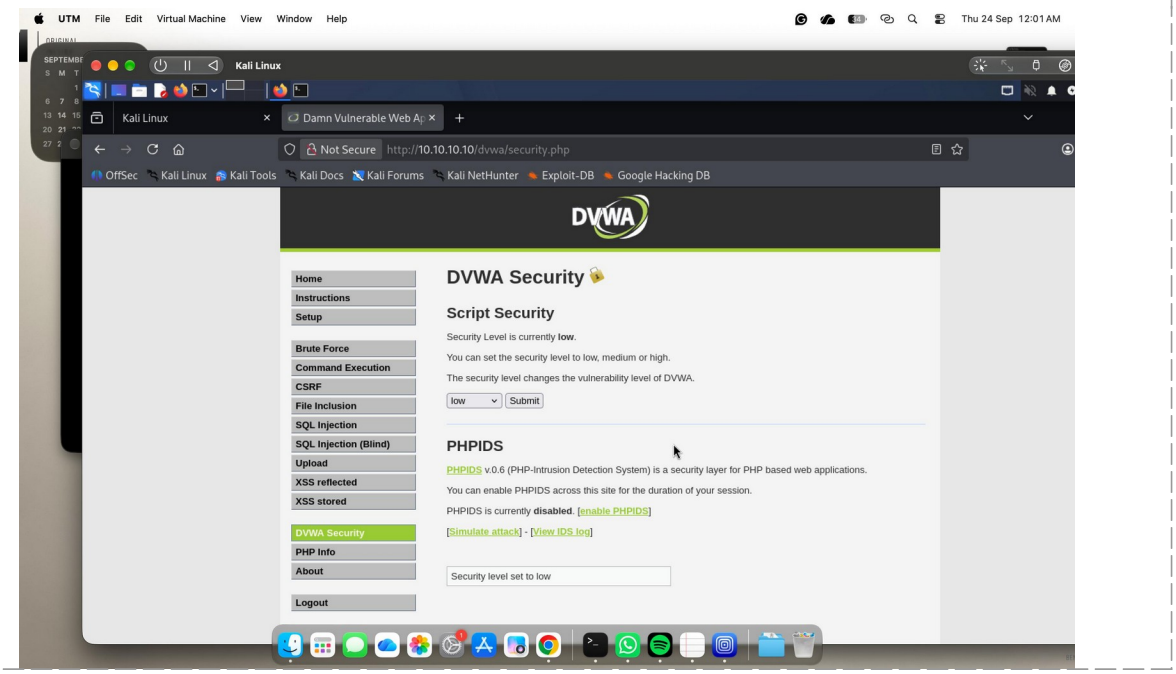
Machine	Role	IP address	Notes
Kali Linux	Attacker	10.10.10.5	Host Only network; used for recon and attacks
Metasploitable2 + DVWA	Target	10.10.10.10	Host Only network; no bridged or NAT adapter — isolated only
Ubuntu Server	Log box / monitoring	10.10.10.20	Host Only network; receives forwarded logs via syslog (UDP 514)

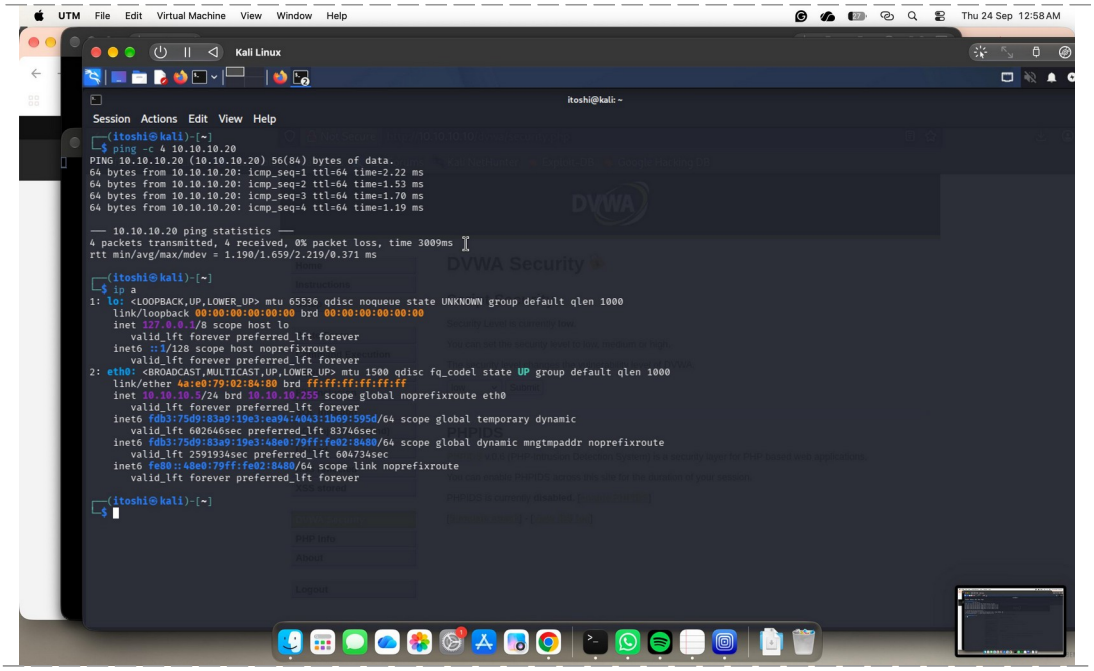
Network diagram



Evidence


UTM File Edit Virtual Machine View Window Help
Wed 23 Sep 11:50 PM
Kali Linux
itoshi@kali: ~
Session Actions Edit View Help
inet 127.0.0.1/8 scope host lo
valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
link/ether 4a:e0:79:02:84:80 brd ff:ff:ff:ff:ff:ff
inet 10.10.10.5/24 brd 10.10.10.255 scope global noprefixroute eth0
valid_lft forever preferred_lft forever
inet6 fdb3:75d9:83a9:19e3:ea94:4043:1b69:595d/64 scope global temporary dynamic
valid_lft 604790sec preferred_lft 85890sec
inet6 fdb3:75d9:83a9:19e3:48e0:79ff:fe02:8480/64 scope global dynamic mngtmpaddr noprefixroute
valid_lft 2591990sec preferred_lft 604790sec
inet6 fe80::48e0:79ff:fe02:8480/64 scope link noprefixroute
valid_lft forever preferred_lft forever
(itoshi㉿kali)-[~]
$ ping -c 4 10.10.10.10
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.
From 10.10.10.5 icmp_seq=1 Destination Host Unreachable
From 10.10.10.5 icmp_seq=2 Destination Host Unreachable
From 10.10.10.5 icmp_seq=3 Destination Host Unreachable
From 10.10.10.5 icmp_seq=4 Destination Host Unreachable
— 10.10.10.10 ping statistics —
4 packets transmitted, 0 received, +4 errors, 100% packet loss, time 3069ms
pipe 4
(itoshi㉿kali)-[~]
$ ping -c 4 10.10.10.10
PING 10.10.10.10 (10.10.10.10) 56(84) bytes of data.
64 bytes from 10.10.10.10: icmp_seq=1 ttl=64 time=4.59 ms
64 bytes from 10.10.10.10: icmp_seq=2 ttl=64 time=0.673 ms
64 bytes from 10.10.10.10: icmp_seq=3 ttl=64 time=0.527 ms
64 bytes from 10.10.10.10: icmp_seq=4 ttl=64 time=0.515 ms
— 10.10.10.10 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3032ms
rtt min/avg/max/mdev = 0.515/1.576/4.590/1.741 ms
(itoshi㉿kali)-[~]
$

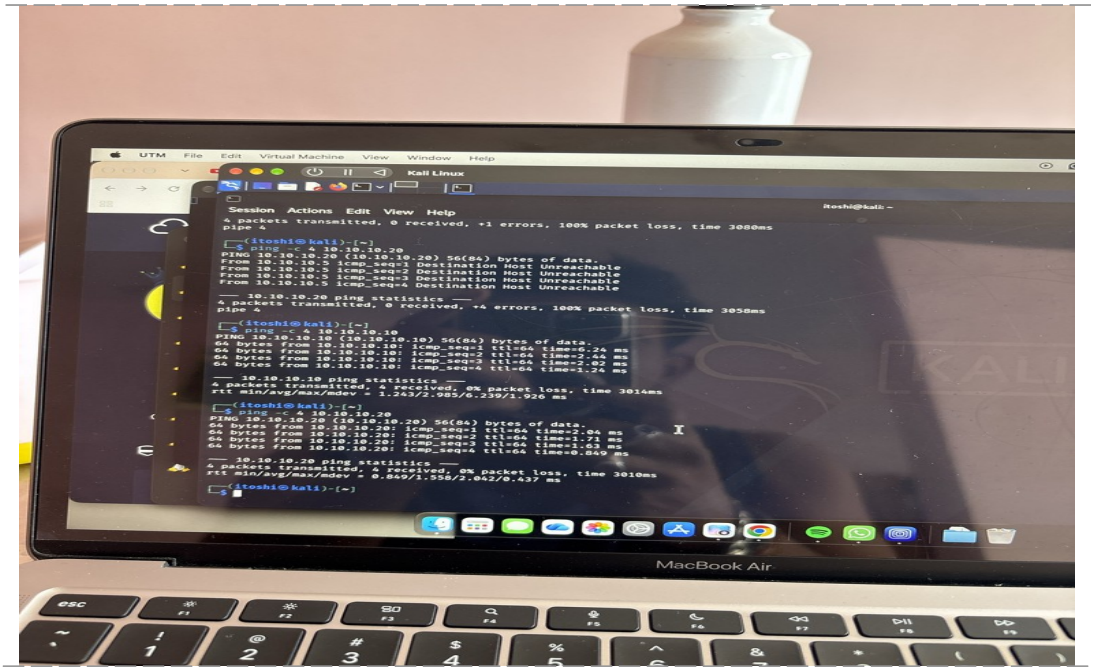

UTM File Edit Virtual Machine View Window Help
Thu 24 Sep 12:01 AM
Kali Linux
Kali Linux
Damn Vulnerable Web Ap
Not Secure http://10.10.10.10/dvwa/security.php
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
DVWA
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
DVWA Security
Script Security
Security Level is currently low.
You can set the security level to low, medium or high.
The security level changes the vulnerability level of DVWA.
low
Submit
PHPIDS
PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.
You can enable PHPIDS across this site for the duration of your session.
PHPIDS is currently disabled. [enable PHPIDS]
[Simulate attack] - [View IDS log]
Security level set to low



Default Metasploitable2 credentials were changed immediately after first login, per the Rules of Engagement.

Network Mode Correction

Initial setup used UTM's Shared Network mode for simplicity during installation, as this was the only mode that reliably assigned IP addresses on first attempt. Before beginning Week 2 attacks, all three VMs (Kali, Metasploitable2 + DVWA target, and the Ubuntu log box) were reconfigured to Host Only mode (Default private network) to ensure full isolation from the internet per the Rules of Engagement. All three machines retained their original static IPs (10.10.10.5 / .10 / .20) after the switch, with no reassignment needed. Connectivity between all three machines was re-verified afterward — see evidence below.



W1-T1.1-network-mode-fix.png — successful ping from Kali (10.10.10.5) to both the target (10.10.10.10) and log box (10.10.10.20) after switching all three VMs from Shared Network to Host Only, confirming isolation was corrected with no loss of connectivity.

Task 1.2 — Asset Inventory

Asset	Type	Owner / Dept	Why it matters
Employee laptops/workstations	Hardware	All departments (IT-managed)	Entry point for phishing/malware; endpoint access to internal systems
Ubuntu web server (hosts customer portal)	Hardware/ Software	Engineering	Runs the production customer-facing app; single point of failure if compromised
Customer portal web app	Software	Engineering	Handles logins, customer data, support tickets — direct attack surface
Internal website	Software	Engineering/IT	Internal comms and resources; lower sensitivity but still a foothold if breached
Customer + employee database	Data	Engineering (data owner), HR (employee records)	Contains PII and credentials — high confidentiality/integrity stakes
Employee accounts and credentials	Data/Personnel	IT/all departments	Compromise cascades to every system an employee can access
Internet-facing connection	Connectivity	IT	The network boundary — the path any external attacker must cross

Task 1.3 — CIA Analysis

Asset	Confidentiality	Integrity	Availability
Customer + employee database	Must stay private — exposure leaks PII and employee records	Must not be altered without authorization	Must be reachable on demand; downtime blocks support/billing
Customer portal web app	Login and session data must not leak	App logic/data must resist injection or tampering	24/7 access needed; outage damages the customer relationship
Employee accounts and credentials	Passwords/tokens must never be exposed	Credentials must not be silently changed or forged	Employees must authenticate to work; lockouts hurt productivity
Ubuntu web server	Configs/secrets must not be exposed	OS/services must not be modified by an attacker	Uptime required for the portal and internal site to function
Internet-facing connection	Traffic should not leak data unencrypted	Traffic must resist interception/tampering (MITM)	Loss of connectivity is a total outage for customers and remote staff

Task 1.4 — Threat & Risk Assessment

Asset	Threat	Vulnerability	Impact	Risk	Recommendation
Customer portal	SQL Injection	Unsanitized input in login/search	Extraction/ modification of customer records	Critical	Parameterized queries; WAF as compensating control
Customer portal	XSS	Unsanitized input rendered to pages	Session hijack, credential theft, defacement	High	Input sanitization + output encoding; CSP
Web server	Brute force (SSH/FTP)	Weak/default passwords, no lockout	Attacker gains shell access	High	Strong password policy + lockout; key-based SSH; disable unused FTP
Web server	Known service vuln (unpatched daemon)	Outdated exposed services	Full remote code execution	Critical	Patch management; disable unused services; segmentation
Employee credentials	Phishing	No MFA, no awareness training	Attacker obtains valid credentials	High	Mandatory MFA; awareness training; email filtering
Customer/ employee DB	Insider threat	Broad access, no audit logging	Unauthorized access/tampering, undetected	Moderate	RBAC (least privilege); enable and monitor audit logs
Internet-facing connection	Man-in-the-middle	Unencrypted/weak traffic	Credentials/data intercepted in transit	Moderate	Enforce HTTPS/TLS everywhere; HSTS; disable legacy protocols
Employee workstations	Malware/ ransomware	No EDR, inconsistent patching	Data loss, lateral movement, disruption	High	EDR/antivirus; automated patching; network segmentation

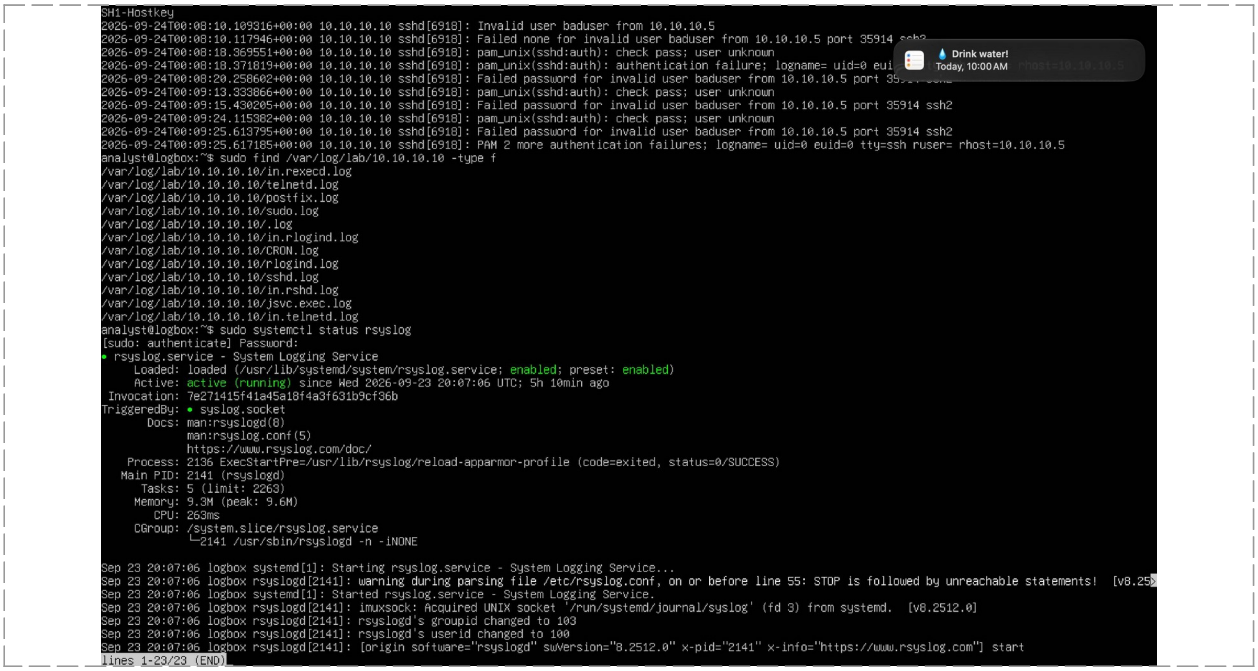
Task 1.5 — Centralized Logging

Manual path (Core): rsyslog configured on the Ubuntu log box to receive UDP syslog on port 514. The target (Metasploitable2, using sysklogd) forwards all facility/priority combinations to the log box's IP.

Configuration summary

- Log box (10.10.10.20): rsyslog imudp module loaded, listening on UDP 514; logs stored under /var/log/lab/<source-ip>/.
- Target (10.10.10.10): /etc/syslog.conf forwards *.* to 10.10.10.20 via UDP.
- AppArmor profile for rsyslog updated to permit read/write under /var/log/lab/.
- Directory ownership corrected to syslog:syslog so rsyslog (running as the syslog user) can create log files.

Evidence





Readiness gate (Week 1): a deliberate failed SSH login from the attacker produced a visible event on the log box, confirmed via the evidence above.

Week 1 Deliverables Checklist

- Lab setup screenshots + network diagram (isolation noted) — see Task 1.1
- Asset Inventory · CIA Analysis · Risk Assessment tables — see Tasks 1.2–1.4
- Log-box screenshot: auth/ssh log arriving + failed-SSH event visible — see Task 1.5
- Progress note (below)
- End-of-Week-1 readiness gate — all boxes passed (pending instructor check-in)

Progress note

- Done: isolated 3-VM lab built in UTM on Apple Silicon (Kali, Metasploitable2+DVWA, Ubuntu log box); connectivity confirmed between all machines.
- Done: Asset Inventory, CIA Analysis, and Threat & Risk Assessment tables completed for SecureCorp's stated assets.
- Done: centralized logging working end-to-end — target forwards via sysklogd, log box receives via rsyslog, failed SSH login confirmed visible with timestamp and source IP.
- Blockers resolved: UEFI/BIOS boot mismatch on the target VM, AppArmor and directory-ownership issues blocking rsyslog on the log box, and a syntax error in the target's forwarding config — all diagnosed and fixed.
- Done: network isolation corrected — all three VMs switched from Shared Network to Host Only mode prior to Week 2; connectivity re-verified with no IP reassignment needed (see Network Mode Correction, Task 1.1).